05

REAL-WORLD INCIDENTS

2017 - 2022

CASE STUDY FILE

Cyber Crime Case Studies

How major attacks happened, what they cost, and the practical lessons that prevent the next one.

SUBMITTED BY

Raval Kirtan

Enrollment No.: _____

CASES COVERED

01 Capital One Cloud Data Breach
02 T-Mobile Customer Data Breach
03 WannaCry Ransomware Worm
04 Cosmos Bank Cyber Heist
05 AIIMS Delhi Ransomware Attack

01 Capital One Cloud Data Breach

United States | Misconfigured firewall, stolen cloud credentials

YEAR	REGION	TYPE	SCALE
2019	USA / Canada	Data breach	~106 million people

WHAT HAPPENED	In March 2019 an intruder accessed data stored by Capital One in a cloud storage service. The bank disclosed the incident on 29 July 2019. About 100 million people in the U.S. and 6 million in Canada were affected, mostly credit-card applicants from 2005 to 2019. A former cloud-provider engineer was later convicted of computer-intrusion and wire-fraud offences.
ATTACK TECHNIQUE	The attacker exploited a misconfigured web application firewall using a server-side request forgery (SSRF) technique. This tricked the server into revealing temporary cloud credentials, which were then used to list and copy storage buckets. It was a configuration and access-control failure, not a phishing attack.
LOSS AND IMPACT	Most exposed data was application information such as names, addresses and credit scores. Roughly 140,000 Social Security numbers and 80,000 bank account numbers were also involved. Capital One estimated costs of up to $150 million for 2019.
RESPONSE	Capital One fixed the configuration, informed the FBI, notified customers and offered free credit monitoring. Regulators later examined its cloud-risk management.
RECOVERY COST AND TIME	The U.S. OCC imposed an $80 million civil penalty (2020) and a customer class action was settled for $190 million (2021). Remediation and security investment continued for years.
HOW IT COULD BE PREVENTED	Least-privilege cloud roles, blocking access to cloud metadata endpoints, correct firewall rules, tokenising or encrypting stored data, and alerts for unusual bucket listing and large downloads.

KEY LESSON

Moving to the cloud does not remove responsibility. One mis-set rule can expose millions of records, so configurations must be reviewed and tested continuously.

02 T-Mobile Customer Data Breach

United States | Exposed network entry point and weak internal controls

YEAR	REGION	TYPE	SCALE
2021	USA	Telecom data theft	~76.6 million people

WHAT HAPPENED	In August 2021 T-Mobile confirmed that an attacker had accessed its systems and stolen customer and prospect records. Data was later offered for sale online. The company's investigation put the number of affected individuals at about 76.6 million.
ATTACK TECHNIQUE	Reports indicate the intruder entered through an exposed network gateway, moved into other systems and then copied large databases. No phishing campaign was needed. The case shows how one weak entry point can lead to widespread internal access.
LOSS AND IMPACT	Exposed fields included names, dates of birth, Social Security numbers and driver's licence or ID details for many people. This raised the risk of identity theft, SIM-swap attempts and targeted scams.
RESPONSE	T-Mobile closed the entry point, hired outside security firms, notified customers, offered two years of identity protection and reset PINs for some accounts. Regulators and courts reviewed the incident.
RECOVERY COST AND TIME	A $350 million class-action settlement was approved, and T-Mobile also committed $150 million to data-security upgrades over the following years. A separate U.S. regulatory settlement followed later.
HOW IT COULD BE PREVENTED	Close or protect exposed management interfaces, segment internal networks, keep sensitive data minimal and encrypted, monitor for mass data exports and run regular penetration tests.

KEY LESSON

Customers trust carriers with identity-level data. Collect less, protect it in layers and assume that one control will eventually fail.

03 WannaCry Ransomware Worm

Global | Self-spreading malware using an unpatched Windows flaw

YEAR	REGION	TYPE	SCALE
2017	Worldwide	Malware / ransomware	200,000+ computers

WHAT HAPPENED	On 12 May 2017 WannaCry spread across more than 150 countries within days, encrypting files and showing a ransom note. Victims included hospitals, manufacturers, telecom firms and government offices. The UK's National Health Service was among the most visible casualties.
ATTACK TECHNIQUE	The worm used the EternalBlue exploit against the Windows SMBv1 protocol to spread from one computer to another without any user click. Microsoft had released a patch two months earlier, but many systems were not updated. The ransom demand was $300 in bitcoin, rising to $600.
LOSS AND IMPACT	Around 19,000 NHS appointments were cancelled and some emergency patients were diverted. The UK government estimated about 92 million pounds in NHS costs and lost output. Global losses were reported in the hundreds of millions to billions of dollars.
RESPONSE	A researcher found and registered a hidden "kill-switch" domain, which slowed the spread. Microsoft issued emergency patches even for unsupported systems. Governments later attributed the attack to a North Korea-linked group.
RECOVERY COST AND TIME	Most NHS systems were restored within days, but clean-up, upgrades and audits took months. Many organisations had to rebuild machines from backups.
HOW IT COULD BE PREVENTED	Install security updates quickly, retire old operating systems, disable SMBv1, segment networks, keep offline backups, and restrict internet exposure of file-sharing ports.

KEY LESSON

Patching is a security control, not routine housekeeping. A worm can outpace any response if systems remain unpatched and flat networks let it travel.

04 Cosmos Bank Cyber Heist

India | Malware on payment switch, cloned cards and SWIFT transfers

YEAR	REGION	TYPE	LOSS
2018	Pune, India	Banking fraud	~Rs. 94 crore

WHAT HAPPENED	On 11 and 13 August 2018, attackers drained about Rs. 94 crore from the Pune-based Cosmos Co-operative Bank in two coordinated phases. Roughly Rs. 78 crore came from card withdrawals made across about 28 countries, and Rs. 13.9 crore was sent by SWIFT to a Hong Kong account.
ATTACK TECHNIQUE	Malware was planted on the bank's ATM-switch infrastructure to approve fraudulent card requests and bypass normal authorisation. Cloned debit cards were then used abroad, while a separate fraudulent SWIFT message moved funds. Staff-level access and weak monitoring helped the attackers.
LOSS AND IMPACT	The bank lost its funds directly, services were disrupted for several days and customer confidence dropped. The case showed that even small co-operative banks are targets for organised international fraud rings.
RESPONSE	The bank shut the ATM switch, alerted card networks, filed a police complaint and Maharashtra Cyber and the CID began an investigation. Some of the SWIFT-transferred money was traced and frozen.
RECOVERY COST AND TIME	The full loss was never publicly recovered in a single amount. Operations returned in stages, but forensic, audit and legal work continued for a long time.
HOW IT COULD BE PREVENTED	Isolate payment switches, enforce multi-factor admin access, review SWIFT messages with dual authorisation, use transaction velocity and geography alerts and run regular independent security audits.

KEY LESSON

Fraud limits work only when approval, monitoring and human checks are separate. Payment systems need layered controls and fast cross-border reporting.

05 AIIMS Delhi Ransomware Attack

India | Critical public-sector systems locked by ransomware

YEAR	REGION	TYPE	IMPACT
2022	New Delhi, India	Ransomware	~2 weeks manual work

WHAT HAPPENED	On 23 November 2022 servers at the All India Institute of Medical Sciences (AIIMS), Delhi, were hit by ransomware. The e-hospital system for registration, billing, lab reports and appointments went offline, and staff reverted to paper-based work. Media reports mentioned a large ransom demand in cryptocurrency, but that figure was not officially confirmed.
ATTACK TECHNIQUE	Investigators described a ransomware infection that encrypted the main servers, reportedly after attackers gained a foothold on part of the network. The exact initial entry method was not publicly confirmed, so it should be described as an unverified pathway.
LOSS AND IMPACT	Thousands of patients faced delays, and doctors had to record data manually. Sensitive health information of patients, including prominent people, was at risk. Reports mentioned roughly five servers and over a terabyte of data affected.
RESPONSE	AIIMS isolated the network, and Indian agencies, including the national cyber-security teams, helped investigate. Systems were rebuilt and brought back in phases, with services mostly restored in about two weeks.
RECOVERY COST AND TIME	No official cost has been published. Costs included lost productivity, forensic work, infrastructure rebuilds and later security upgrades such as network segmentation.
HOW IT COULD BE PREVENTED	Segment clinical and administrative networks, use offline backups with restore drills, enable multi-factor authentication, monitor endpoints, patch regularly and train staff to report suspicious activity.

KEY LESSON

Healthcare cannot afford long downtime. Resilience means tested backups, segmented networks and a rehearsed manual fallback, not just prevention.

Comparison at a Glance

Common causes across all five incidents

Case	Year	Main cause	Main impact	Core control that was missing
Capital One	2019	Misconfigured firewall, SSRF	~106M people's data	Cloud least privilege
T-Mobile	2021	Exposed entry point	~76.6M records stolen	Network segmentation
WannaCry	2017	Unpatched SMBv1 flaw	200,000+ systems, NHS disruption	Timely patching
Cosmos Bank	2018	Malware on payment switch	~Rs. 94 crore stolen	Transaction monitoring
AIIMS Delhi	2022	Ransomware	~2 weeks manual operations	Tested backups, segmentation

Key Takeaways

- Most major incidents started with a basic gap: an unpatched system, a wrong setting or an exposed entry point.
- Layered controls (segmentation, encryption, monitoring and backups) limit how far an attacker can go.
- Speed matters: quick patching, fast detection and rehearsed response cut both cost and downtime.
- Report facts carefully. Figures such as costs and record counts come from company filings, regulators and news reports, and some are estimates.